

(주)다운컨택 수탁사 개선 방안 보고서

수탁사 (피감사)	(주)다운컨택
위탁사 (감사 주체)	(주)하랑항공
위탁 업무 범위	하랑항공 고객센터(CS) 상담 대행 일체
점검 기간	2026년 01월 26일 ~ 2026년 02월 13일
작성일	2026년 02월 23일

본 보고서는 (주)다운컨택의 개인정보 보호 관리 수준을 점검한 결과를 바탕으로,
각 취약 사항에 대한 구체적인 개선방안과 이행 계획을 기술한 문서입니다.

목차

1. 개선방안 요약	3
1.1 보안 준수율 분류 기준	3
1.2 조치 기한 분류 기준	3
2. 범주별 개선방안 상세	4
2.1 내부 관리 계획 및 조직	4
2.2 접근 통제 및 권한 관리	5
2.3 접속기록 보관 및 점검	6
2.4 비밀번호 관리	6
2.5 접속 보안 및 네트워크	7
2.6 단말기 보안	7
2.7 개인정보 암호화 및 출력 통제	8
2.8 개인정보 생명주기	9
3. 이행 점검 로드맵	10
4. 결론 및 향후 조치 계획	11
4.1 향후 조치 일정	11

1. 개선방안 요약

1.1 보안 준수율 분류 기준

분류	양호(Y)	부분양호(P)	취약(N)
점수	1	0.7	0

총점	100 ~ 90	89 ~ 70	69 ~ 50	49 ~ 0
등급	A	B	C	D

- 각 점검항목을 양호, 부분양호, 취약으로 평가하여 분류한다.
- 총점은 53개의 점검항목 점수의 합산을 100점 만점으로 환산한 값이다.
- 환산 점수에 따라 90점 이상 A등급, 70~89점 B등급, 50~69점 C등급, 49점 이하 D등급으로 산정한다.

1.2 조치 기한 분류 기준

구분	긴급	단기	중기
조치 기한	4주	2개월	6개월

- 지적 사항의 심각도에 따라 조치기한을 3단계로 구분한다.
- 개선방안 이행은 긴급, 단기, 중기 순으로 추진한다.

2. 범주별 개선방안 상세

2.1 내부 관리 계획 및 조직

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
출력물 관리	VOC 출력물 방치, 파기 예정 문서 재활용통 투기, 보안캐비닛 잠금 미적용	부서별 출력물 수거함 잠금 적용, 출력물 수거·파쇄 작업 절차서 재수립, 야간 청소 전 문서 수납 의무화	보안팀장 김민준 총무팀장 최수아

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
내부관리계획서	침해사고 통지 기한 미반영, 위험분석 방법론 미정의, 재위탁 감독 절차 누락, 내부관리계획서 정기 검토 부재	보호법 현행 기준(72시간) 반영 및 전면 개정, 위험분석 방법론 명시, 재위탁 감독 실행절차 추가, 내부관리계획서 정기 검토 시기 지정, 최고경영책임자 결재 의무화	보안팀장 김민준
공지·교육	법령 개정 후 공지 미실시, 신규 입사자 체크리스트 미포함, 미이수자 40명 보완 교육 미실시	개정 사항 즉시 전사 재공지, 체크리스트 개정, 미이수 40명 보완 교육 완료 후 CPO 보고	개인정보보호팀장 이서연
침해사고 대응	비상연락망 미갱신, 72시간 신고 의무 조항 누락, 금년 모의훈련 미실시	비상연락망 분기 1회 검토 의무화, 대응절차서 신고 의무 조항 추가, 연 1회 이상 모의훈련 일정 즉시 수립	보안팀장 김민준
위기대응 매뉴얼	개인정보처리시스템 전용 BCP(RTO/RPO 포함) 미수립,	개인정보처리시스템 전용 BCP 수립 및 RTO/RPO 목표값 명시, 연 1회 이상 복구 테스트 정기 실시	IT인프라팀장 박지호 보안팀장 김민준

구분	현황·문제점	개선 방안	담당자
	최근 1년간 복구 테스트 이력 없음, 위기대응 계획서 내 위탁사 통보 절차 미포함	및 이력 보관, 위기대응 계획서 내 위탁사 통보 절차 추가	
취급자 관리	신규 파견 상담원 3명 취급자 목록 미등록 후 VDI 계정 발급	계정 발급 전 취급자 목록 등록 조건 추가, HR-계정 시스템 등록 자동 연동 점검	IT인프라팀장 박지호
서버실 관리	전자 자동기록 미구축(수기 출입기록부 운영), 서버 랙 잠금 미적용	전자 출입이력 시스템 도입, 서버 랙 잠금 장치 설치, 분기 1회 정기 검토 이력 관리 체계 수립	IT인프라팀장 박지호

2.2 접근 통제 및 권한 관리

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
공용·root 계정	IT인프라팀 CTI 공용계정 사용, DB root 앱 접속 (전년 반복)	개인 계정 전환 이행 계획서 수립 후 단계적 전환, root 계정 앱 접속 즉시 차단	IT인프라팀장 박지호
스탠바이 서버	PAM 모듈 계정 잠금 정책 미적용	스탠바이 서버 PAM 정책 동일 수준 적용, 분기 1회 설정 검토 절차 추가	IT인프라팀장 박지호

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
계정 구분	외부직원· 임시직원에 대해 내부직원과 구분된 사번 체계계정 발급	외부직원 계정 발급 이력 전수 조사를 통해 계정 구분 규칙 준수 여부를 확인, 중요정보 접근권한 부여 현황을	보안팀장 김민준 IT인프라팀장 박지호

구분	현황·문제점	개선 방안	담당자
	검증 누락	주기적으로 점검하는 절차를 수립	
승인 프로세스	CTI 계정 발급 시 CPO 승인 단계 생략, 긴급 계정 사후 승인 프로세스 미수립	CPO 승인 단계 필수 적용, 긴급 계정 사후 관리 프로세스 자동화	보안팀장 김민준 IT인프라팀장 박지호
접근 권한 기록 체계	접근 권한 기록 보관 기간 미달	이력 보관 정책 3년으로 상향	IT인프라팀장 박지호

2.3 접속기록 보관 및 점검

점검 결과 등급: D

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
정기 검토	담당자 퇴직 후 후임 미지정, 4개월간 검토 미실시, 공백 기간 소급 분석 미실시	후임 담당자 즉시 지정, 공백 4개월 소급 분석, 대체 담당자 지정	보안팀장 김민준
보관 기간	접속 기록 보관 기간 미준수 (6개월), 로그 저장 공간 부족, 무결성 방지 대책 미흡	보관 기간 1년으로 정책 개정, 외부 스토리지·로그 서버 분리, WORM 매체 활용	IT인프라팀장 박지호 보안팀장 김민준

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
이상 접근 탐지	자동 탐지 솔루션 미운영	SIEM 솔루션 도입 검토, 공백 기간 이상 징후 탐지	보안팀장 김민준

2.4 비밀번호 관리

점검 결과 등급: A

해당 항목 전체 양호 판정으로 현재 시점 개선 필요 사항 없음

2.5 접속 보안 및 네트워크

점검 결과 등급: B

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
클립보드 공유	VDI 환경 클립보드 복사 미차단	VDI 클립보드 정책 양방향 차단 설정	IT인프라팀장 박지호
개인 서비스 차단	개인 이메일·개인 클라우드 스토리지 접근 허용 상태	방화벽·웹 필터 차단 도메인 목록 추가, 매체 제어 및 유출 경로 차단	IT인프라팀장 박지호

2.6 단말기 보안

점검 결과 등급: C

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
공유폴더 노출	파일 서버 공유폴더에 고객 개인정보 엑셀 파일 다수 존재, 접근통제·암호화·로그 부재	기본 공유폴더 비활성화, DRM 및 파일 단위 암호화 적용, 파일 서버 감사 로그 활성화	IT인프라팀장 박지호
보안패치	일부 개인정보취급자 PC·단말기 보안 패치 미적용	PC·단말기 최신 보안 패치 업데이트	IT인프라팀장 박지호
USB 차단	USB 포트 미차단, GPO 화이트리스트 미적용, 관리대장 5개월 미작성	GPO USB 포트 차단 정책 수립, USB 포트 일괄 차단, 업무 기기 화이트리스트 등록, 전자 승인 기반 관리대장 자동화	IT인프라팀장 박지호 보안팀장 김민준

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
스탠바이 서버	OS 보안패치 3개월 이상 지연, 위험 수용 절차 부재	지연 패치 즉시 이행, 매월 정기 패치 검토 대상에 스탠바이 서버를 포함, 위험 수용 절차 및 예외 처리 프로세스 문서화	IT인프라팀장 박지호

2.7 개인정보 암호화 및 출력 통제

점검 결과 등급: C

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
암호화 키 관리	암호화 키 관리 부재, 소스코드 하드코딩 (전년 반복)	암호화 키 관리대장 작성 및 현행화, 소스코드 내 하드코딩 제거, HSM·KMS 솔루션 도입	보안팀장 김민준 개발팀장 강하은
DB 개인정보 저장	고객 휴대폰번호·성명 VARCHAR 평문 저장, 개선 계획 미수립 (전년 반복)	암호화 대상 컬럼 선정, 대칭키 암호화 적용, 마이그레이션 계획 수립 및 CPO 보고	개발팀장 강하은 DBA팀장 윤도현
녹취 파일 암호화	녹취 서버 평문 저장, 암호화 검토 미실시	녹취 파일 생성 시 파일 단위 암호화 저장 방식 도입, 재생 시 복호화 접근 이력 로깅 연동	IT인프라팀장 박지호 DBA팀장 윤도현

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
출력물 관리대장	전체 출력 건 기록 누락, 보조저장매체 복사 기록 부재	통합 출력 관리 자동 시스템 구축, 야간 및 예외 시간대 모니터링 강화, 출력물 관리 프로세스 통합	개인정보보호팀장 이서연
CTI 서버 전송	CTI·DB 서버 간 TCP 통신 암호화 미적용	내부 서버 간 통신 TLS 적용	IT인프라팀장 박지호

2.8 개인정보 생명주기

점검 결과 등급: C

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
제3자 제공 관리	제3자 제공 관리대장 최근 1년 기록 부재, 개인정보 파일 외부 전송 자동 탐지 수단 미수립	관리대장 기록 즉시 재개, DLP 솔루션 도입 및 운영, 정보유출 방지 가이드 수립	개인정보보호팀장 이서연 보안팀장 김민준

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
문서 파기 절차 현장 준수	파기 예정 문서를 재활용 쓰레기통에 투기	개인정보 파기 절차 준수 교육 실시, 파기 완료 확인서 작성	개인정보보호팀장 이서연
파기 결과 보고	하랑항공 파기 결과 보고 최근 1년 미이행 (전년 반복)	소급 보고 즉시 수행, 파기 결과 자동 보고 시스템 구축, 관리 책임자 지정 및 프로세스 도입	개인정보보호팀장 이서연
재위탁 관리	재위탁사(스카이메시지) 연 1회 보안 점검 미실시, 계약서 손해배상·교육 의무 누락	재위탁 계약서 조항 보완, 연 1회 보안 점검 일정 수립, 재수탁사 임직원 교육 의무화	법무팀장 인채원 보안팀장 김민준

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당부서/담당자
분리 보관	전수 매핑 미완료, 녹취 파일 보존·파기 기준 미확정, 자동 파기 프로세스 부재	전수 매핑 실시, 녹취록 보존 가이드라인 수립, 자동 파기 및 분리 보관 처리 자동화 구현	개인정보보호팀장 이서연 DBA팀장 윤도현

3. 이행 점검 로드맵

개선방안 이행은 아래 3단계 로드맵에 따라 추진하며, 각 단계 완료 시 (주)하랑항공 개인정보보호팀에 이행 결과를 보고한다.

각 단계 완료 후 이행 결과보고서(증적자료 포함)를 (주)하랑항공 개인정보보호팀장에게 제출한다.

이행 중 기술적 제약, 예산 문제 등으로 일정 변경이 필요한 경우 사전 협의 후 서면 승인을 득하여야 한다.

단계	기간	주요 이행 항목	이행 결과 보고 기한
긴급 조치	~2026.04.30	신규 파견 상담원 취급자 목록 등록 / 공용·root 계정 전환 계획 수립 / 접속기록 담당자 재지정 및 소급 분석 / USB 전면 차단 GPO 배포 / 미패치 단말 업데이트 / 공유폴더 암호화 및 접근통제 / 암호화 키 관리대장 작성 및 하드코딩 제거	2026년 05월 12일
단기 조치	~2026.07.12	내부관리계획서 현행화 / 출력물 관리 SOP 재수립 / 클립보드·개인 이메일·클라우드 접근 차단 / 제3자 제공 관리대장 기록 재개 / 파기 결과 보고 자동화 / 재위탁 계약서 보완 / SFT·TLS 전환	2026년 07월 12일
중기 조치	~2026.10.12	DB 고객 정보 암호화(AES-256) 구현 / 녹취 파일 암호화 적용 / 암호화 키 관리 체계(KMS) 도입 / SIEM 솔루션 도입 / DLP 솔루션 도입 / 재위탁사 현장 보안 점검 실시 / 분리 보관 전수 매핑 완료	2026년 10월 12일
재점검	2026.11월 중	(주)하랑항공 현장 재점검 실시 — 전 항목 이행 완료 여부 및 잔존 취약점 재확인	2026년 11월 중

4. 결론 및 향후 조치 계획

(주)다운컨택은 이번 점검에서 확인된 총 31건(취약 12건, 부분양호 19건)의 취약 사항에 대한 구체적인 개선방안을 수립하여 이행할 책임이 있다. 특히 퇴사자 계정 장기 잔존, 접속기록 법정 보관 기간 미달, DB 내 개인정보 평문 저장, 파기 결과 위탁사 보고 미이행은 전년도에 동일하게 지적되었음에도 개선되지 않은 반복 위반 사항으로, 금번 개선방안 이행에 있어 최우선 순위로 처리하여야 한다.

위탁사인 (주)하랑항공은 수탁사의 이행 상황을 아래 일정에 따라 모니터링하고, 이행이 지연되거나 불충분한 경우 계약 조항에 따라 필요한 조치를 취할 수 있다.

4.1 향후 조치 일정

구분	일정	내용
조치계획서 제출	2026년 04월 29일까지	(주)다운컨택 → (주)하랑항공 제출 (담당자 서명 필수)
긴급 항목 이행 보고	2026년 05월 12일까지	공용계정·접속기록·공유폴더·USB·미패치 단말·암호화 키 관리 이행 결과 보고
단기 항목 이행 보고	2026년 07월 12일까지	내부관리계획서·CPO 승인·출력물·파기보고·TLS-SFTP·재위탁 계약 이행 결과 보고
중기 항목 이행 보고	2026년 10월 12일까지	DB 암호화·KMS·SIEM·DLP 등 이행 결과 보고
현장 재점검	2026년 11월 중	(주)하랑항공 주관 현장 재점검 실시 (전 항목 확인)